Phase 12: API Business & Technical Analysis

Document Code: API-DOC-001

Project: Duplicate Bin SaaS Platform

Framework: FastAPI / REST & WebSockets (ASGI)

Approach: Business Meaning First, Followed by Technical Implementation

1. API Architecture Overview

The Duplicate Bin SaaS backend (`backend/app/main.py`) acts as the central coordination and telemetry hub for distributed client desktop agents. It exposes:

- **11 REST Endpoints:** Handling identity, fleet pairing, telemetry ingestion, dashboard analytics, and billing.
- **2 Persistent WebSocket Relays:** Managing full-duplex bi-directional command dispatch and live progress broadcasting.

2. Comprehensive API Endpoint Analysis

2.1 `POST /api/auth/register`

- **Business Meaning:** Enables a new customer (creator or company IT manager) to create a centralized account to track multi-device storage savings.
- **Business Function:** Identity Creation & Initial Credit Grant.
- **Actor:** Prospective Customer.
- **Authentication:** None (Public endpoint).
- **Inputs:** `schemas.UserCreate` (email: string, name: string, password: string [min 8 chars]).
- **Outputs:** `schemas.UserResponse` (id: UUID, email: string, name: string, credit_bytes: integer, plan: string).
- **Business Rules:**
- Duplicate emails are rejected.
- Automatically provisions 10 GB ($10,737,418,240$ bytes) of free deduplication credits.

- Default subscription plan initialized to "SaaS Premium" during introductory launch.
- **Technical Implementation:**
- *Method & Path:* `POST /api/auth/register` (Status 201 Created).
- Passwords hashed using Bcrypt (`passlib.context.CryptContext`).
- SQLAlchemy model `models.User` saved to database.
- **Error Cases:** `400 Bad Request` ("Email already registered").
- **Stakeholder Impact:** Direct acquisition funnel entry point.

2.2 `POST /api/auth/login`

- **Business Meaning:** Authenticates an authorized user and issues a cryptographic digital passport to manage devices.
- **Business Function:** Session Establishment & Token Issuance.
- **Actor:** Registered User / Manager.
- **Authentication:** HTTP Basic credentials payload.
- **Inputs:** `schemas.UserLogin` (email, password).
- **Outputs:** `schemas.Token` (access_token: JWT string, token_type: "bearer").
- **Business Rules:** Account must match active registered user; passwords validated against Bcrypt salt hash.
- **Technical Implementation:**
- *Method & Path:* `POST /api/auth/login` (Status 200 OK).
- Issues HS256 signed JWT with claim `sub: user_id` and 60-minute expiration.
- **Error Cases:** `400 Bad Request` ("Incorrect email or password").

2.3 `GET /api/devices/pairing-code`

- **Business Meaning:** Generates a temporary, human-friendly 6-digit numeric code displayed on the web dashboard to link a new physical office computer.
- **Business Function:** Zero-Configuration Pairing Token Handshake.
- **Actor:** Authenticated Account Owner.

- **Authentication:** Bearer JWT required (`auth.get_current_user`).
- **Inputs:** None (Derived from Bearer Token).
- **Outputs:** JSON object `{"code": "629104", "expires_in_seconds": 300}`.
- **Business Rules:**
- Code consists of exactly 6 random digits (`secrets.choice`).
- Code expires strictly after 300 seconds (5 minutes).
- Code is stored in an in-memory dictionary bound to `user_id`.
- **Technical Implementation:** `PAIRING_CODES[code] = {"user_id": current_user.id, "created_at": utcnow()}`.
- **Stakeholder Impact:** Eliminates the complexity of entering long API keys on command-line workstations.

2.4 `POST /api/devices/pair`

- **Business Meaning:** Binds a specific desktop machine (e.g., "Elena's MacBook" or "Studio-PC-04") to the user's SaaS account.
- **Business Function:** Workstation Registration & Cryptographic Token Exchange.
- **Actor:** Local Desktop Agent (`run.py pair <code>`).
- **Authentication:** Unauthenticated REST call carrying valid pairing code.
- **Inputs:** `schemas.DevicePairRequest` (pairing_code: string, device_id: string, name: string, os: string).
- **Outputs:** JSON `{"device_id": UUID, "pairing_token": hex64, "message": "Device paired successfully"}`.
- **Business Rules:**
- If code is invalid or > 300 seconds old, request is rejected.
- Generates a permanent 64-character hexadecimal `pairing_token` stored locally on the client.
- Used pairing codes are deleted immediately to prevent replay attacks.
- **Technical Implementation:** Upserts `models.Device` record; commits transaction to SQLite/PostgreSQL.
- **Error Cases:** `400 Bad Request` ("Invalid or expired pairing code").

2.5 `GET /api/devices`

- **Business Meaning:** Lists all computers registered under the organization and indicates which ones are currently powered on and connected.
- **Business Function:** Fleet Inventory & Online Presence Monitoring.
- **Actor:** IT Administrator / Manager.
- **Authentication:** Bearer JWT required.
- **Outputs:** List of `schemas.DeviceResponse` (id, name, os, is_active, last_seen, created_at).
- **Business Rules:** `is_active` status is evaluated in real-time by inspecting whether the device ID is currently in the active WebSocket connection registry.
- **Technical Implementation:** Queries `models.Device.filter_by(user_id=...)` and cross-references `manager.active_agents`.

2.6 `POST /api/scans/telemetry`

- **Business Meaning:** Ingests the business outcome of a completed workstation cleanup, updating company savings totals and debiting user credits.
- **Business Function:** Telemetry Ingestion & Credit Ledger Debit.
- **Actor:** Desktop Agent Daemon.
- **Authentication:** Validated via registered device ID.
- **Inputs:** `schemas.ScanResponse` (id: UUID, device_id: UUID, status: "completed"|"failed", path_scanned: string, files_count: integer, duplicates_count: integer, bytes_recoverable: integer, duration_seconds: float).
- **Outputs:** JSON `{"message": "Telemetry processed successfully"}`.
- **Business Rules:**
- Deducts `bytes_recoverable` from the user's `credit_bytes` balance **only once** upon initial transition to "completed".
- Failed or running scans do not debit user credits.
- **Technical Implementation:**

- Updates or creates `models.Scan` row.
- Atomically updates `models.User.credit_bytes -= deduct_amount`.
- **Error Cases:** `404 Not Found` (Device or User not found).

2.7 `GET /api/dashboard/stats`

- **Business Meaning:** Provides executive leadership with clear financial and technical proof of storage recovered and ROI achieved across all corporate machines.
- **Business Function:** Executive Aggregate Reporting.
- **Actor:** Business Owner / IT Director.
- **Authentication:** Bearer JWT required.
- **Outputs:** `schemas.DashboardStatsResponse` (total_bytes_saved: integer, total_files_processed: integer, total_duplicates_found: integer, active_devices_count: integer, credit_bytes: integer, plan: string, scans_history: list).
- **Business Rules:** Aggregates metrics using SQL `func.sum()` across all devices owned by the authenticated user for scans marked `status == 'completed'`.
- **Technical Implementation:** SQLAlchemy aggregation query on `models.Scan.device_id.in_(user_device_ids)`.

2.8 `POST /api/scan/trigger`

- **Business Meaning:** Allows a central manager to initiate a deduplication scan on a remote employee workstation or server without physical machine access.
- **Business Function:** Remote Scan Orchestration.
- **Actor:** IT Administrator.
- **Authentication:** Bearer JWT required.
- **Inputs:** Query parameters: `device_id` (UUID), `path` (target directory string).
- **Outputs:** JSON `{"scan_id": UUID, "status": "running"}`.
- **Business Rules:**
- Machine must be paired to the authenticated user.

- Machine must be currently connected via an active WebSocket session.
- **Technical Implementation:** Asynchronously transmits JSON packet `{"type": "CMD_START_SCAN", "payload": {...}}` over the agent's WebSocket connection.
- **Error Cases:** `400 Bad Request` ("Device is currently offline"), `404 Not Found` ("Device not paired to this user").

2.9 `POST /api/billing/buy-credits` & `POST /api/billing/upgrade-plan`

- **Business Meaning:** Facilitates monetization by letting prosumers top up their pay-as-you-go credit pool or upgrade company tiers.
- **Business Function:** Monetization & Subscription Management.
- **Actor:** Account Owner.
- **Authentication:** Bearer JWT required.
- **Inputs:** `buy-credits`: `{"bytes_to_buy": 107374182400}` (100 GB); `upgrade-plan`: `{"plan_name": "Business Premium"}`.
- **Outputs:** Confirmation message and updated credit balance / active plan.
- **Business Rules:** Increments `user.credit_bytes` atomically.
- **Technical Implementation:** Updates `models.User` record and commits transaction.

2.10 WebSocket Endpoints: `/ws/agent` & `/ws/dashboard`

- **Business Meaning:** The live digital nervous system connecting desktop workstations, cloud relays, and browser dashboards in real-time.
- **Technical Channels:**
- `/ws/agent?device_id=...&token=...`: Validates agent pairing token; registers connection in `manager.active_agents`; listens for `AGENT_PROGRESS` and `AGENT_COMPLETE`.
- `/ws/dashboard?token=...`: Validates JWT token; registers browser client; relays progress broadcasts from all user agents directly to the active web screen.
- **Security Control:** Non-matching pairing tokens or expired JWTs receive immediate connection closure (`WS_1008_POLICY_VIOLATION`).